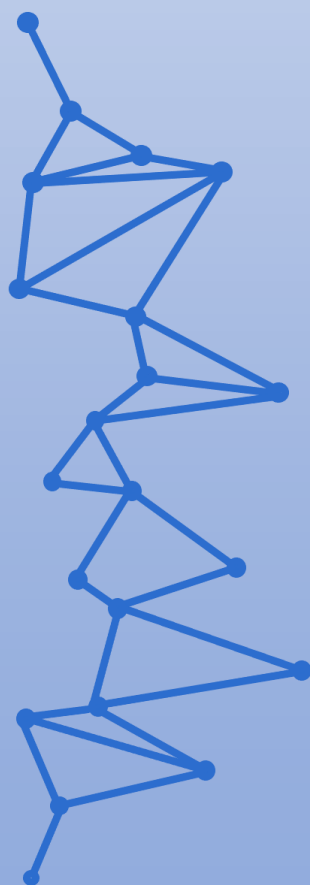




Curso de Especialización de Ciberseguridad en Entornos de Tecnología de la Información (CETI)



Bastionado de redes y sistemas

UD09. Configuración de sistemas
informáticos.
Tarea Online.

JUAN ANTONIO GARCIA MUELAS

INDICE

	Pag
1. Descripción de la tarea	2
2. No será posible acceso remoto con root	2
3. Bloquear sesión tras 5 minutos de inactividad	4
4. Usuarios deben acceder con clave público/privada	5
5. Acceso permitido a cierto usuario	8
6. Acceso basado en filtrado host en lugar del fichero .rhosts	9
7. Implementar versión segura	10
8. No es posible que se realice "Port-forwarding" ni "X11 Forwarding"	11
9. Mensaje al inicio de sesión	12
10. Establecer protocolo de cifrado SHA2-512, SHA2-256	14
11. Los logs están activados para reenvío a SOC	15
12. Webgrafía	17

1.- Descripción de la tarea.

¿Qué te pedimos que hagas?

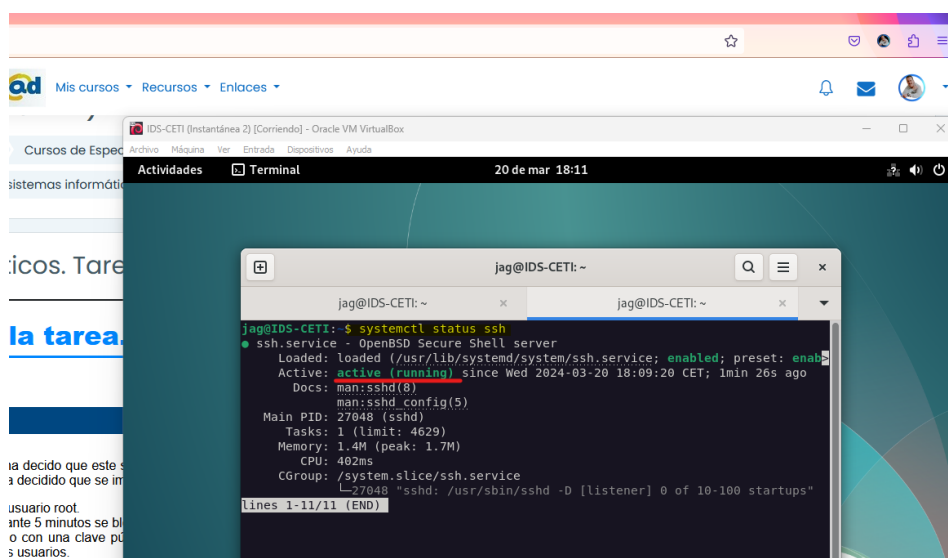
Responsable de la Seguridad de la empresa ha decidido que este servicio crítico y tan utilizado por los administradores tiene que ser bastionado, de cara aumentar el nivel de seguridad de las tareas asociada a la utilización del SSH. Por lo que ha decidido que se implementen las siguientes medidas de seguridad:

1. No será posible el acceso remoto con el usuario root.

Accedemos desde una máquina Debian utilizada en otras tareas a su consola y comprobamos el estado del servidor SSH

systemctl status ssh

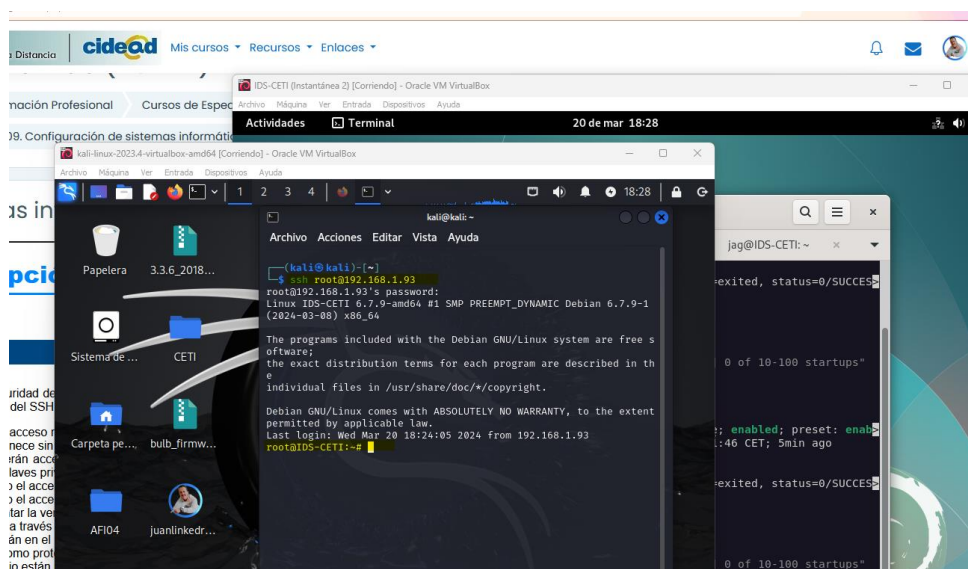
Comprobamos que está activo.



Desde una máquina Kali Linux, vamos a comprobar si puede conectarse como usuario **root**.

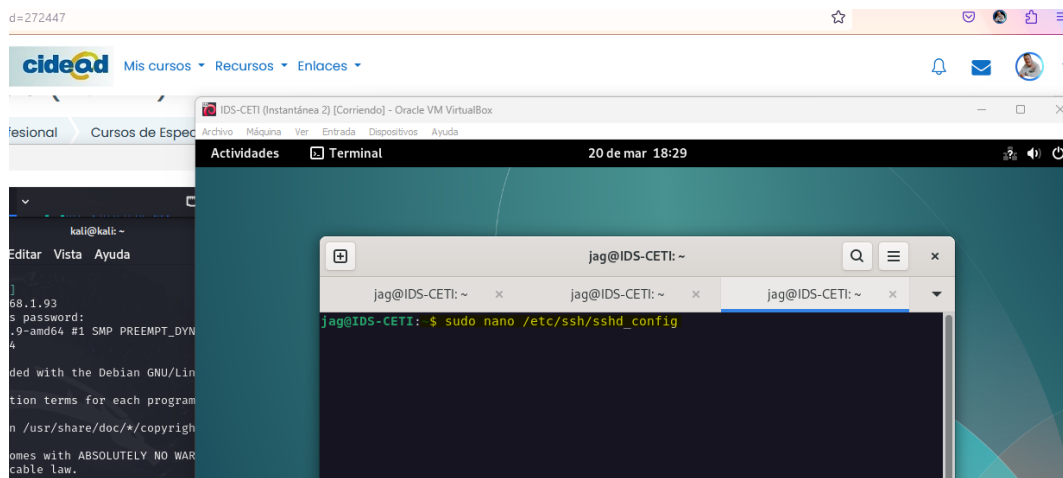
ssh root@192.168.1.93

y vemos que tiene acceso a la máquina Debian llamada **IDS-CETI**.



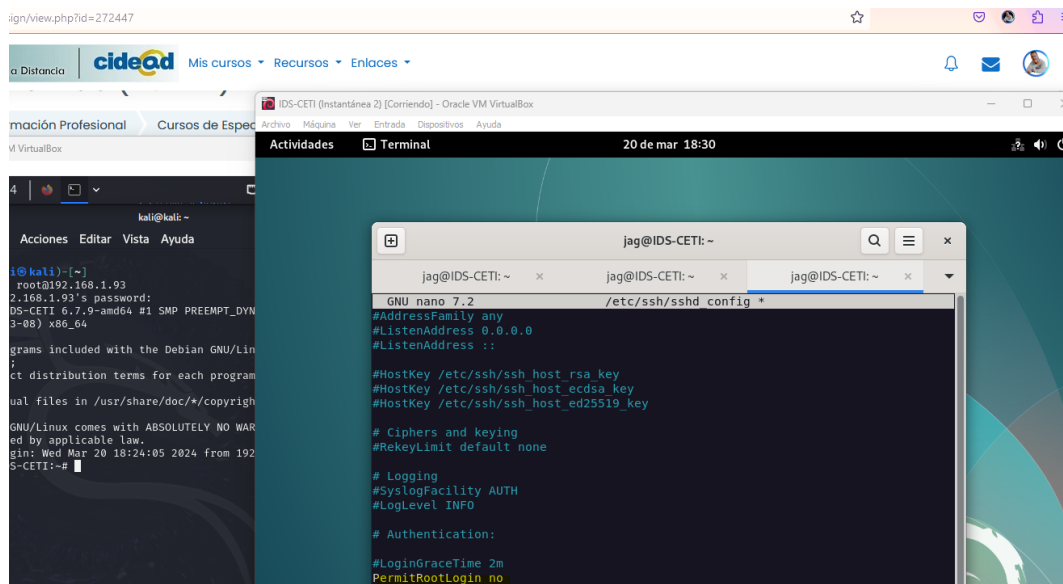
Entramos a editar el archivo de configuración del servidor en la maquina IDS-CETI

sudo nano /etc/ssh/sshd_config



Modificamos la siguiente directiva para evitar el acceso root remoto:

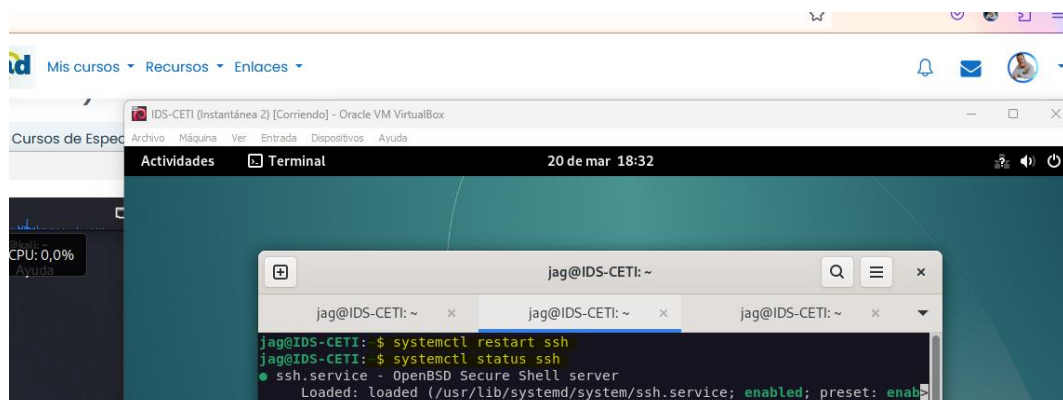
PermitRootLogin no



Guardamos el fichero. Reiniciamos el servidor y comprobamos que todo está OK:

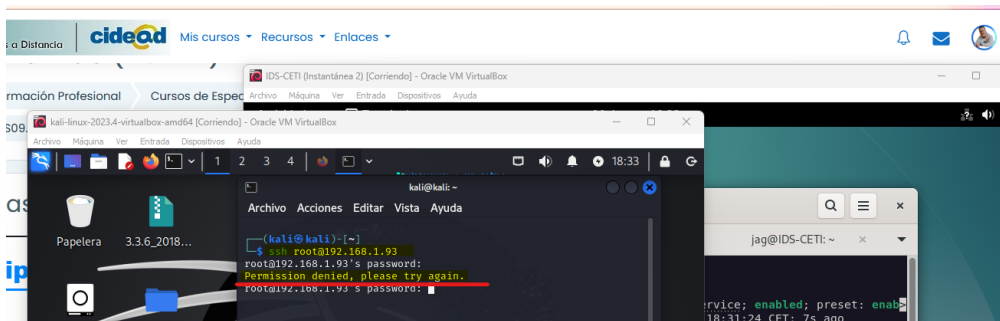
systemctl restart ssh

systemctl status ssh

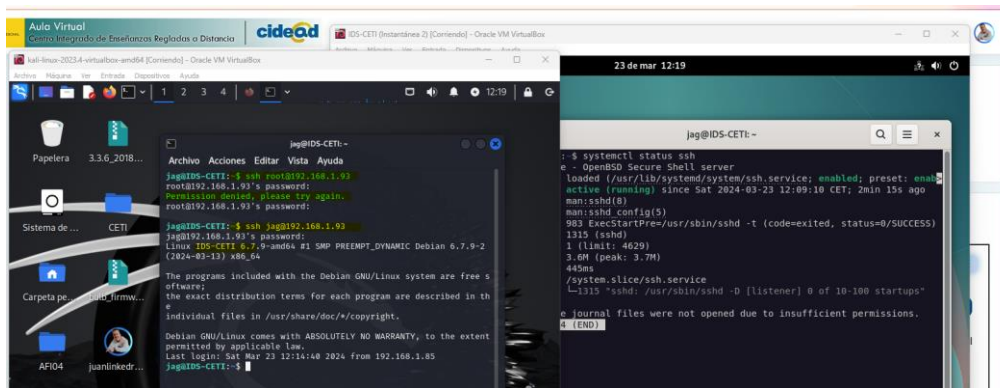


Intentamos de nuevo acceder y nos lo deniega

```
ssh root@192.168.1.93
```



Vemos que, sin embargo, es posible la conexión con otro usuario.



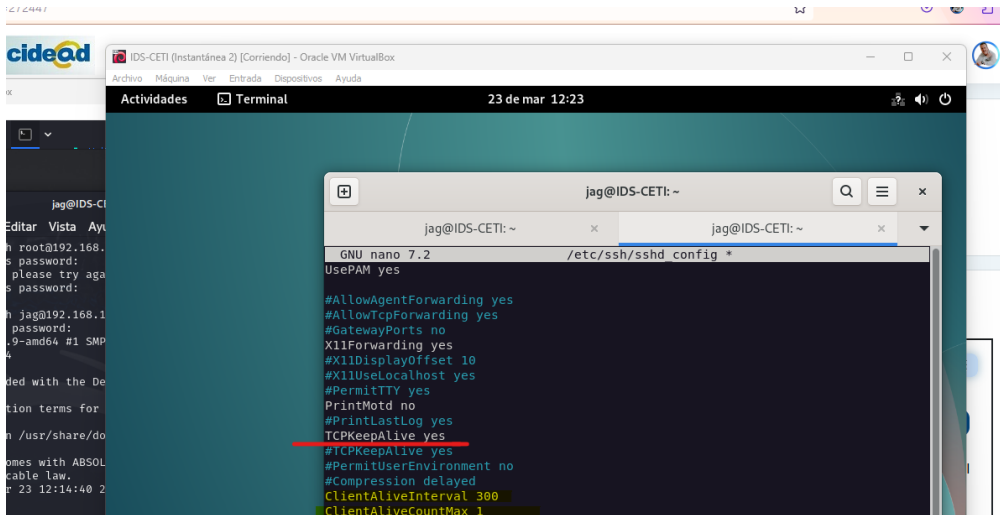
2. Si la sesión permanece sin actividad durante 5 minutos se bloqueará.

Volvemos a acceder al fichero de configuración en `/etc/ssh/sshd_config`

Y modificamos las directivas:

ClientAliveInterval 300 # 5 minutos

ClientAliveCountMax 1s #ponemos el valor de mensajes sin respuesta



El parámetro **TCPKeepAlive** lo mantenemos con el valor por defecto.

A los cinco minutos la sesión se bloquea si no mantiene actividad y el usuario deberá autenticarse de nuevo.

3. Los usuarios deberán acceder al servicio con una clave público/privada. Las claves privadas de los usuarios deberán tener configurados los permisos correctamente para que un usuario no pueda manipular claves privadas de otros usuarios.

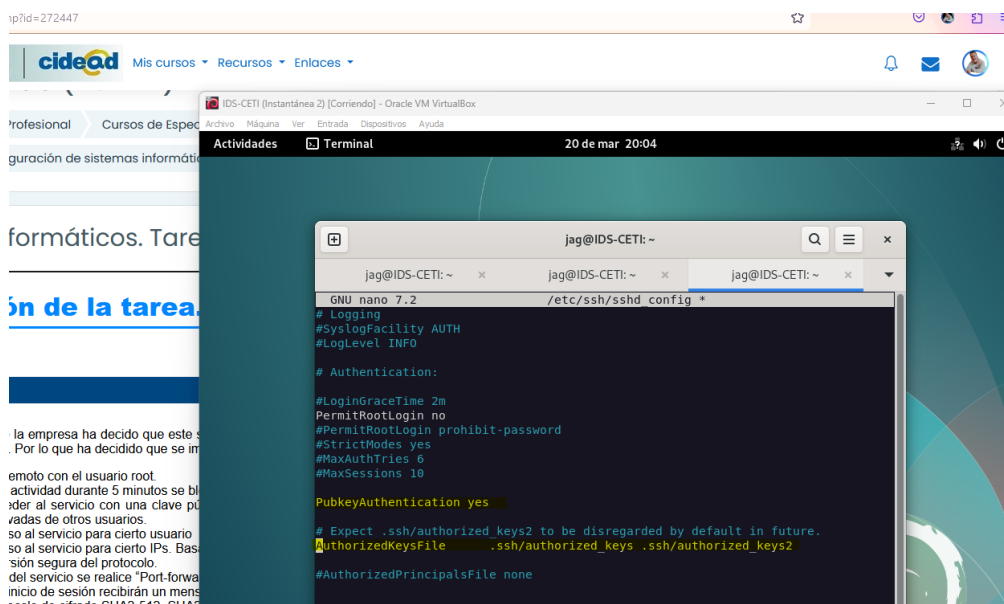
Editamos el archivo de configuración:

```
sudo nano /etc/ssh/sshd_config
```

Buscamos la directiva **PubkeyAuthentication** para habilitar la clave pública y configurarla con **yes**, y le indicaremos la ruta del archivo de claves a **AuthorizedKeyFiles**.

PubkeyAuthentication yes

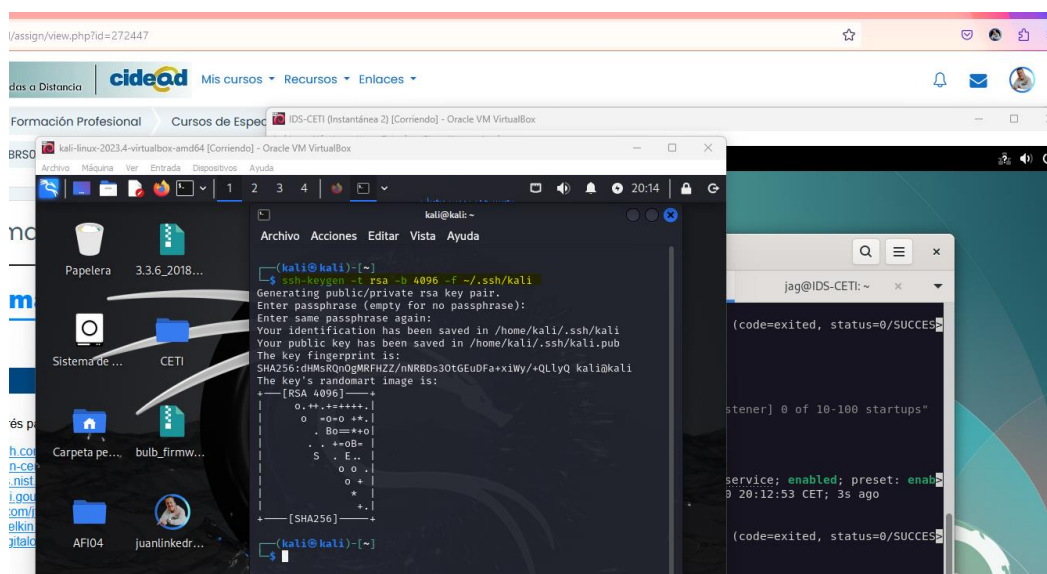
AuthorizedKeysFile .ssh/authorized_keys .ssh/authorized_keys2



Guardamos, reiniciamos el servidor SSH con **systemctl restart ssh** y vamos a editar el archivo de claves.

Para ello vamos a la máquina Kali y generamos las claves:

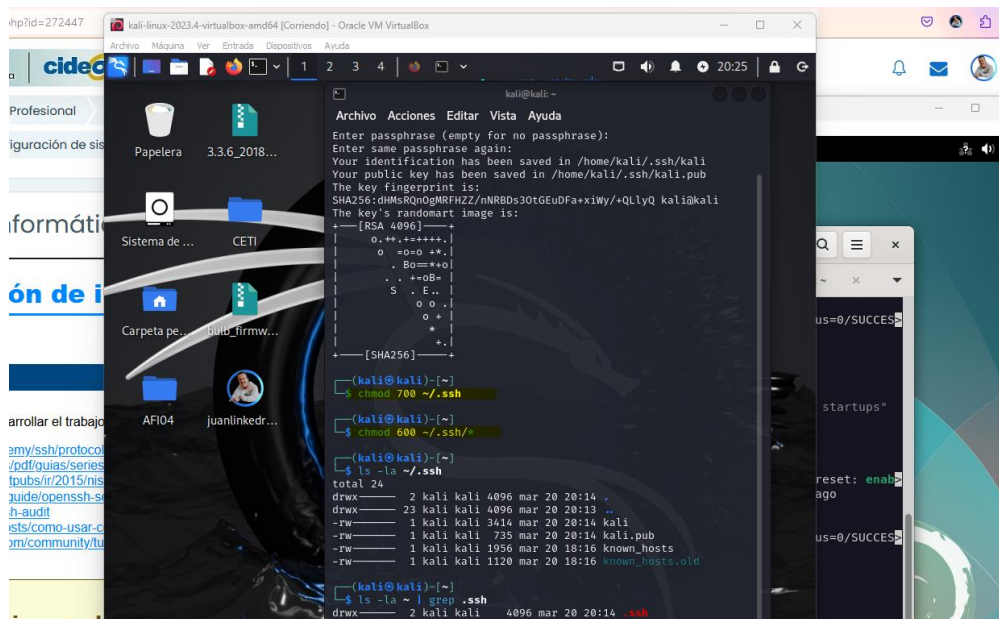
```
ssh-keygen -t rsa -b 4096 -f ~/.ssh/Kali
```



Por seguridad, configuramos los permisos para la clave.

```
chmod 700 ~/.ssh
```

```
chmod 600 ~/.ssh/*
```



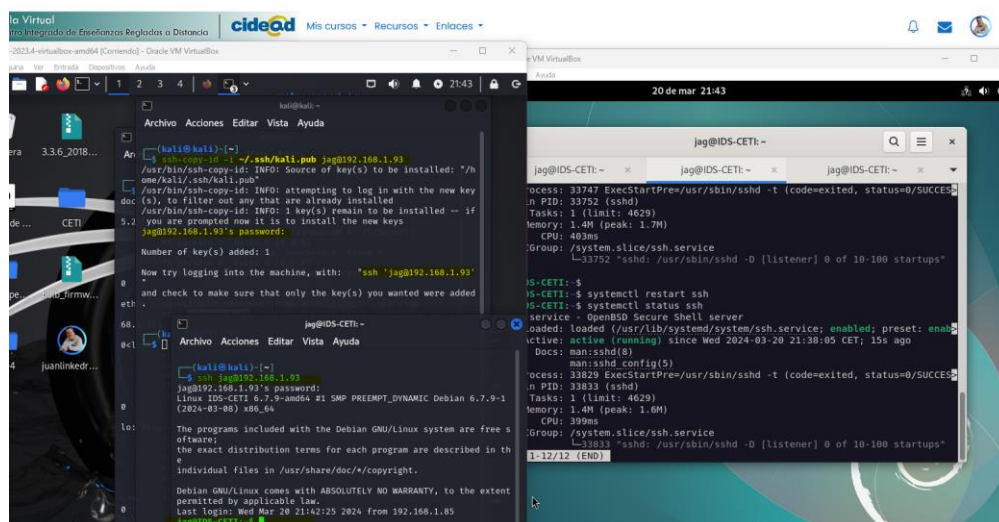
Copiamos ahora la clave desde la máquina **kali** al servidor.

```
ssh-copy-id -i ~/.ssh/kali.pub jag@192.168.1.93
```

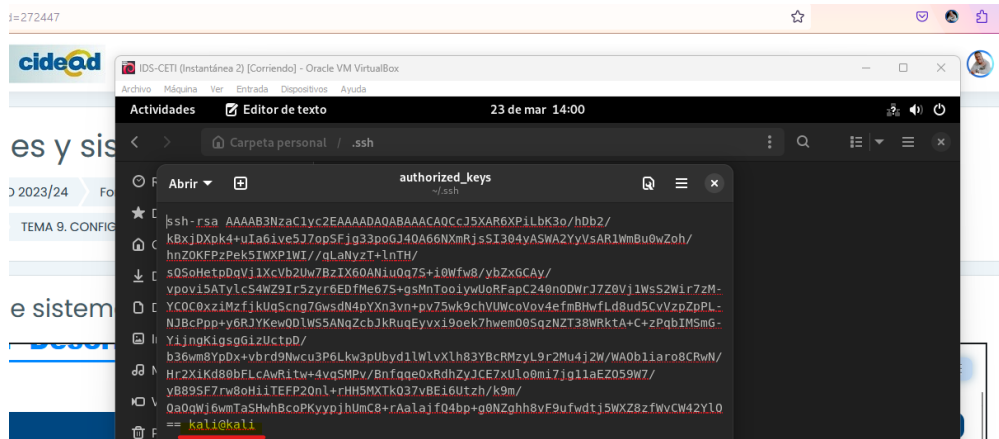
Probamos como nos indica a realizar la conexión.

Lo hacemos según esa indicación con el mismo acceso que hasta ahora, y por tanto nos pedirá la contraseña.

```
ssh jag@192.168.1.93
```

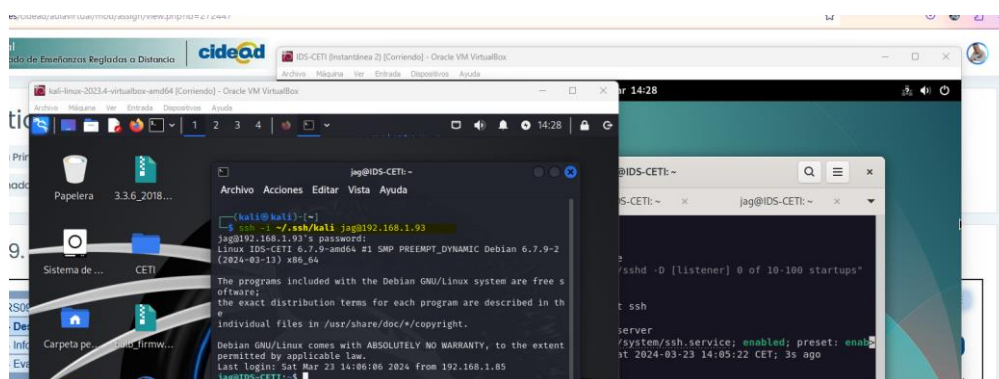


Podemos comprobar en la máquina servidor que la clave se ha copiado correctamente:



Probamos la conexión con la clave generada:

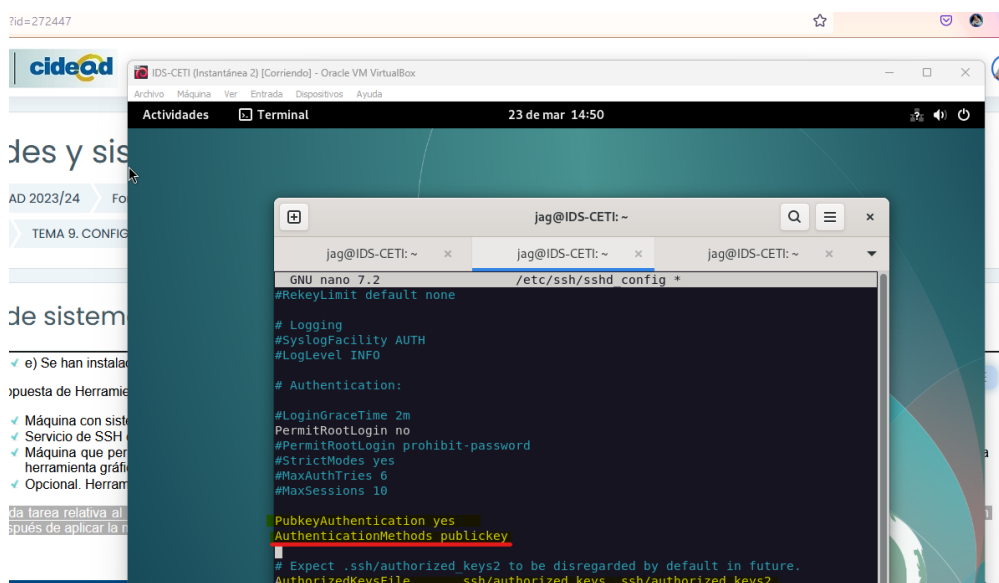
```
ssh -i ~/.ssh/Kali jag@192.168.1.93
```



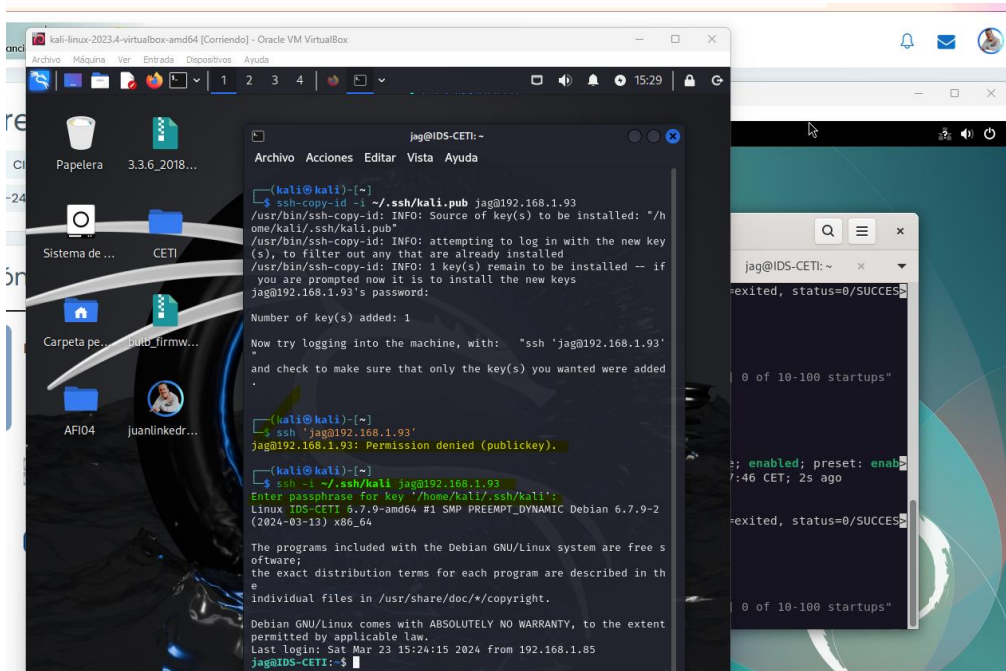
Vemos que sigue autorizando por **password**, así que vamos a mejorar la configuración, que de forma predeterminada nos solicita la contraseña y le diremos que solo pida la clave:

```
sudo nano /etc/ssh/sshd_config
```

```
AuthenticationMethods publickey
```



Volvemos a probar y comprobamos que el acceso es a través de la clave:

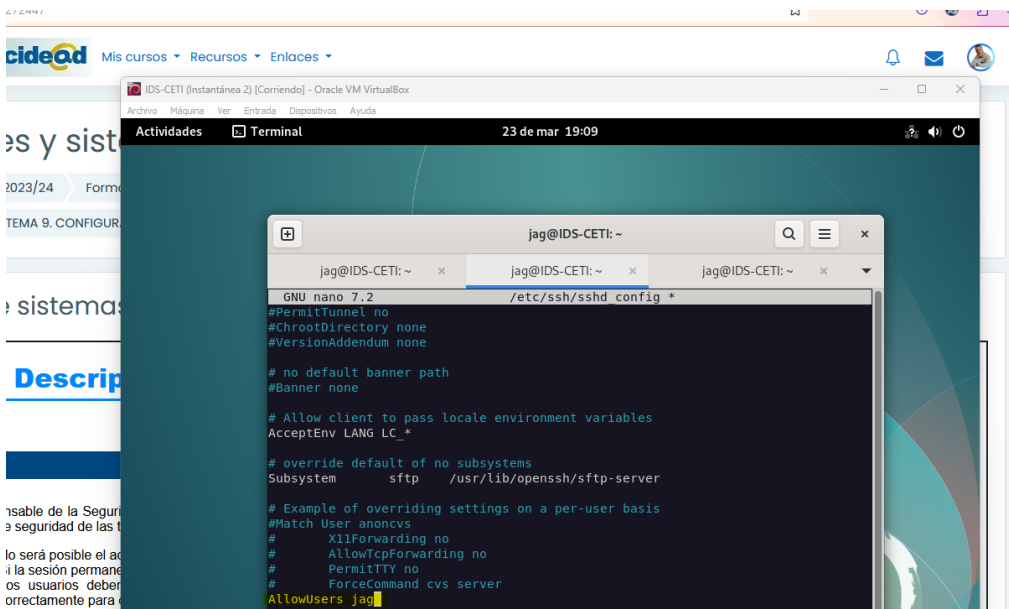


Vemos también como rechaza cualquier conexión que no utilice la clave generada.

4. Sólo está permitido el acceso al servicio para cierto usuario

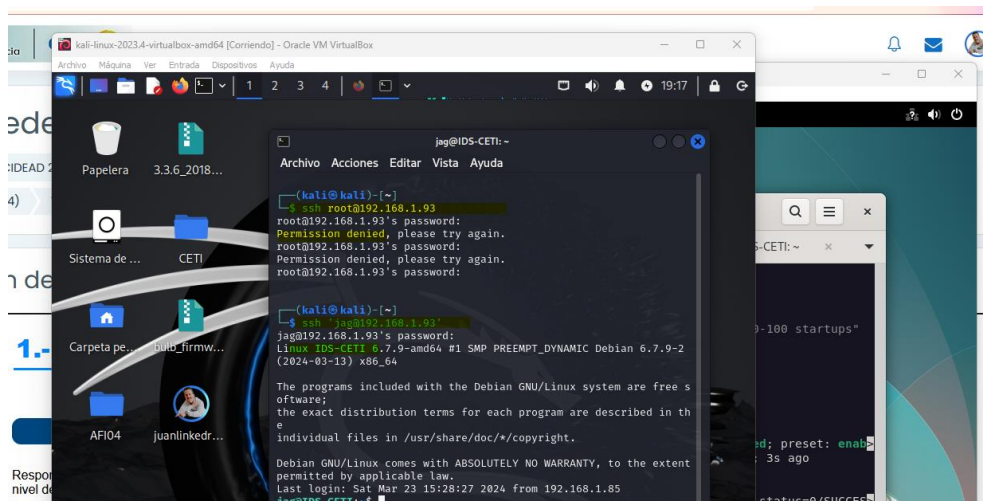
Para este apartado modificamos en la configuración la directiva **AllowUsers** para permitir el acceso al usuario que determinemos.

AllowUsers jag



Habilitamos de nuevo al usuario **root**. Luego guardamos y reiniciamos el servidor con **systemctl restart ssh**

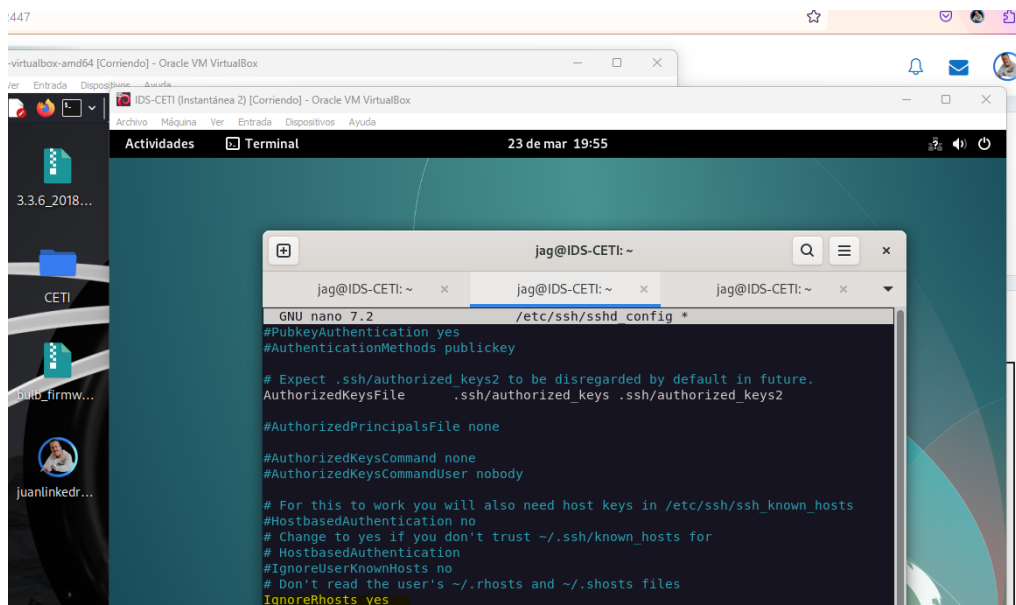
Vamos a comprobarlo:



Solo permite el acceso con el usuario indicado.

5. Sólo está permitido el acceso al servicio para cierto IPs. Basar la confianza de los equipos en parámetros de filtrado host de SSH en lugar del fichero `.rhosts`

Vamos a desactivar la autenticación basada en estos archivos. Volvemos al fichero de configuración mediante `sudo nano /etc/ssh/sshd_config` y activamos la directiva `IgnoreRhosts` poniendo el valor en `yes`



Guardamos y reiniciamos el servidor con `systemctl restart ssh`

Lo siguiente es abrir para edición el fichero `/etc/hosts.allow`

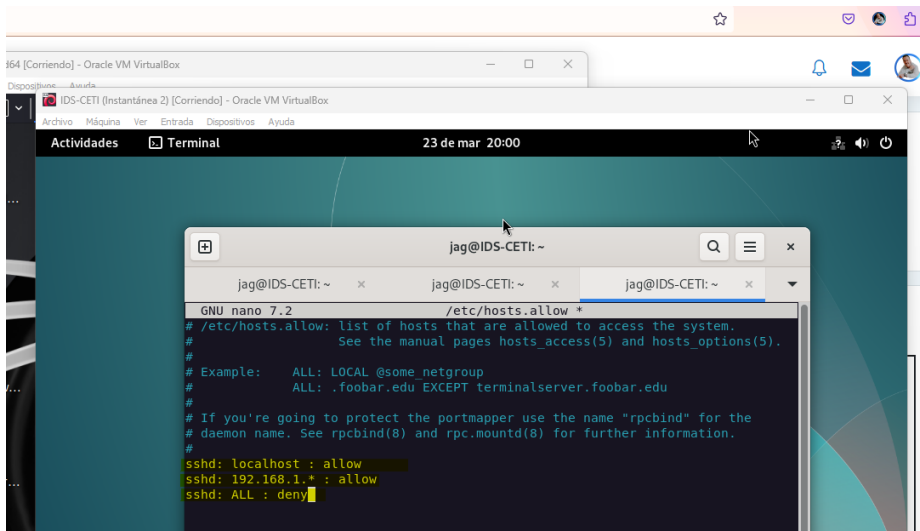
Aquí añadimos el servicio ssh y las IP permitidas, negando el resto.

```
sshd: localhost : allow
```

```
sshd: 192.168.1.*: allow
```

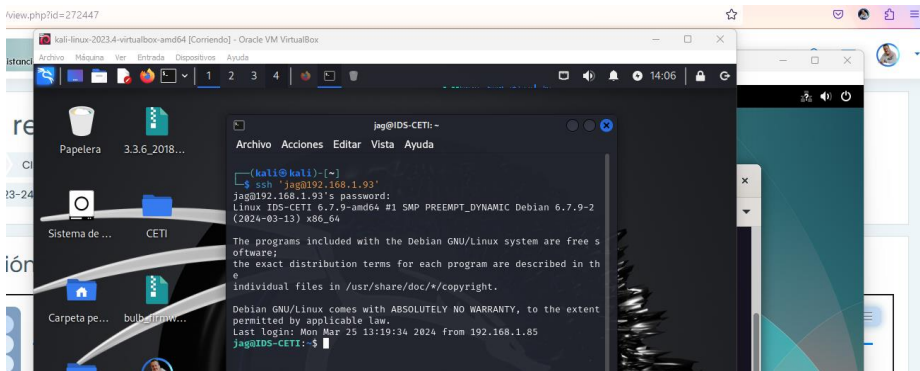
```
sshd: ALL: deny
```

La denegación debe ir al final, pues lee de arriba abajo.



Guardamos y reiniciamos el servidor `systemctl restart ssh`

Comprobamos que se accede sin problemas.

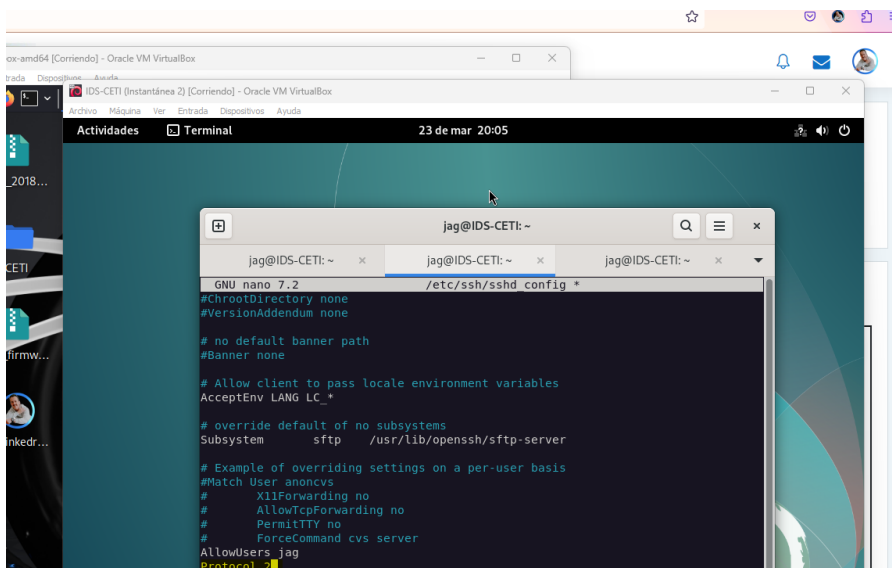


Mantendré esta configuración para comprobar el acceso en el punto 7 por localhost.

6. Se debe implementar la versión segura del protocolo.

Dentro del fichero de configuración indicamos a la directiva **Protocol** que asegure que use la versión 2 de SSH, más segura que la versión 1.

Protocol 2



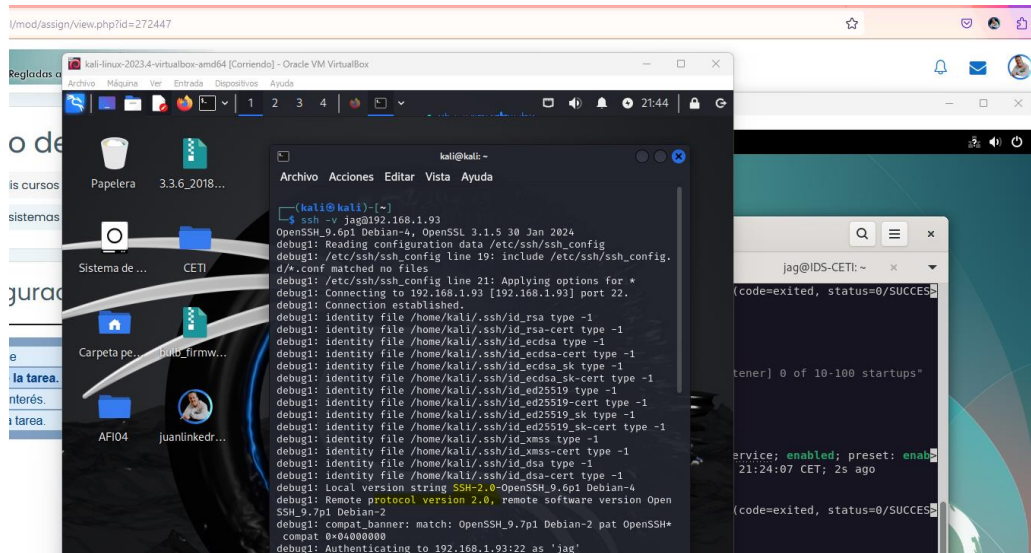
Guardamos y reiniciamos el servidor.

```
systemctl restart ssh
```

```
systemctl status ssh
```

Comprobamos que utiliza la nueva versión de protocolo.

```
ssh -v jag@192.168.1.93
```

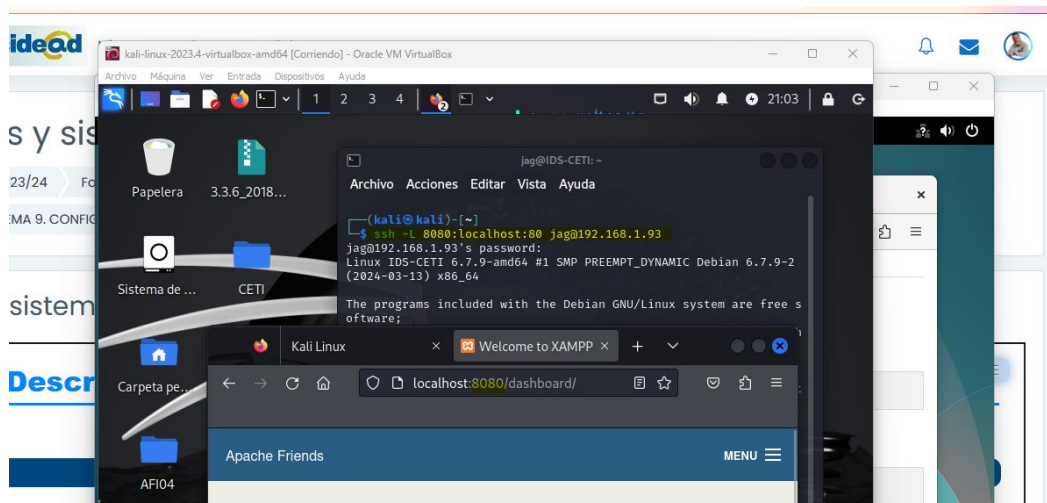


7. No es posible que a través del servicio se realice "Port-forwarding" ni "X11 Forwarding".

Probamos si actualmente es posible:

```
ssh -L 8080:localhost:80 jag@192.168.1.93
```

Comprobamos que es posible acceder a través del puerto 8080.



Vamos al archivo de configuración.

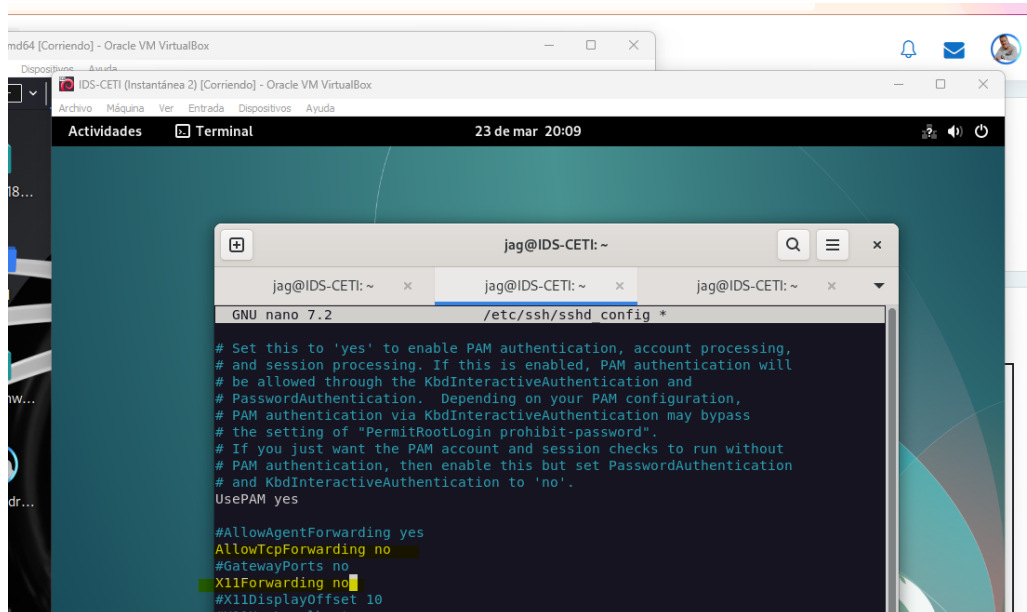
```
sudo nano /etc/ssh/sshd_config
```

Modificamos las directivas:

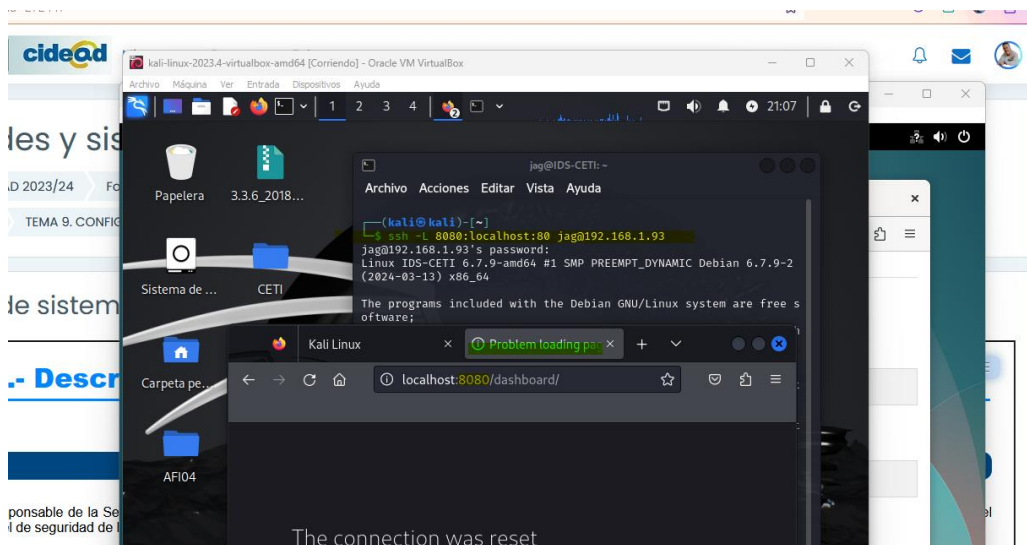
```
AllowTcpForwarding no
```

```
X11Forwarding no
```

Estas directivas suelen venir por defecto en **yes**, aunque la primera estaría comentada. Si en algún momento deseamos deshabilitar todos los **Forwarding**, iremos a la línea **DisableForwarding** y le pondremos un **yes**.



Guardamos y reiniciamos. Si volvemos a intentarlo, ya no será posible.

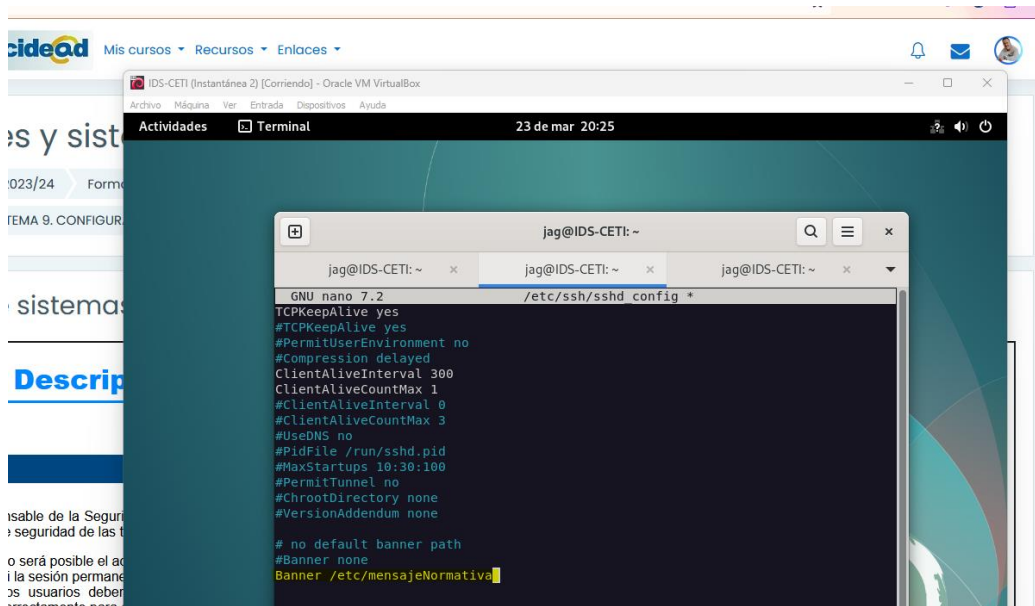


8. Los usuarios recibirán en el inicio de sesión un mensaje indicando el tipo de sistema al que están accediendo y la obligación de cumplir con la normativa interna de la empresa.

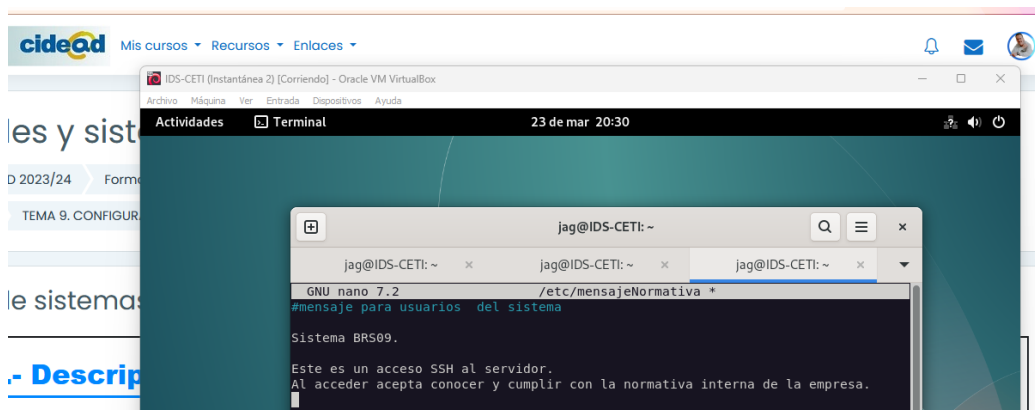
Con la directiva **Banner** configuramos este apartado.

Por conveniencia, suele ponerse como **/etc/motd** (message of the day) pero para el ejemplo le damos este nombre más gráfico.

Banner /etc/mensajeNormativa



Creamos por ejemplo con **nano** el archivo **mensajeNormativa**.

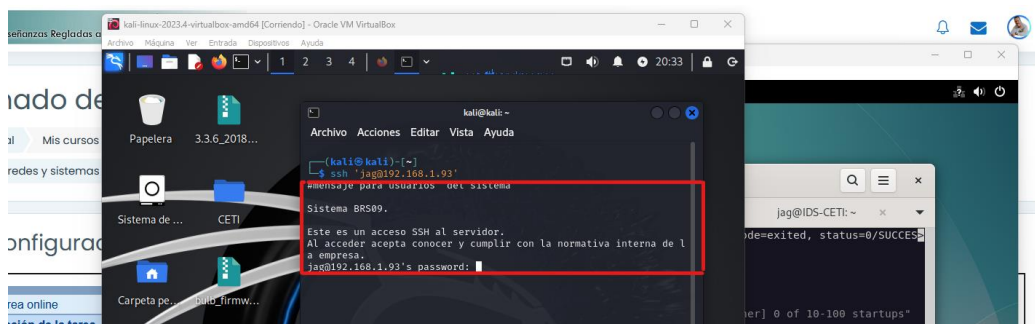


Guardamos y reiniciamos el servidor SSH.

```
systemctl restart ssh
```

```
systemctl status ssh
```

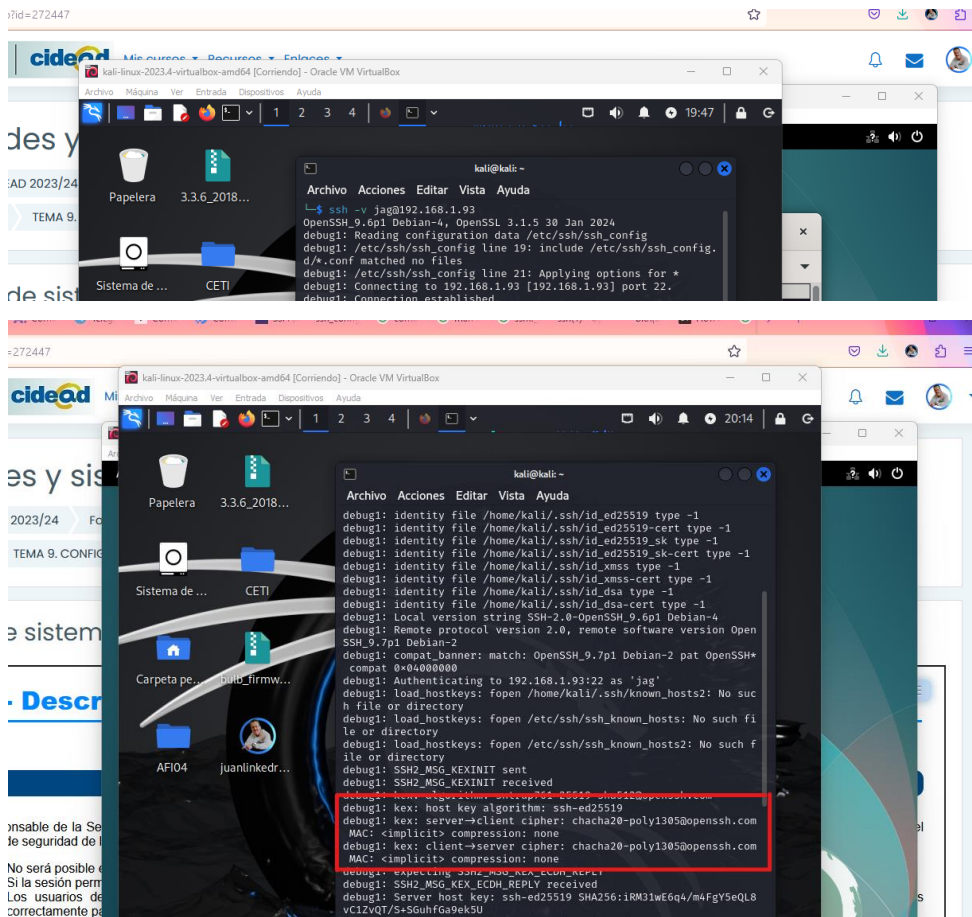
Probamos ahora con un intento de conexión y vemos que nos aparece el mensaje para poder acceder.



9. Se establecerán como protocolo de cifrado SHA2-512, SHA2-256.

Si accedemos con la opción `-v` como hicimos en un apartado anterior, podemos ver entre otros datos, el protocolo de cifrado actual

```
ssh -v jag@192.168.1.93
```

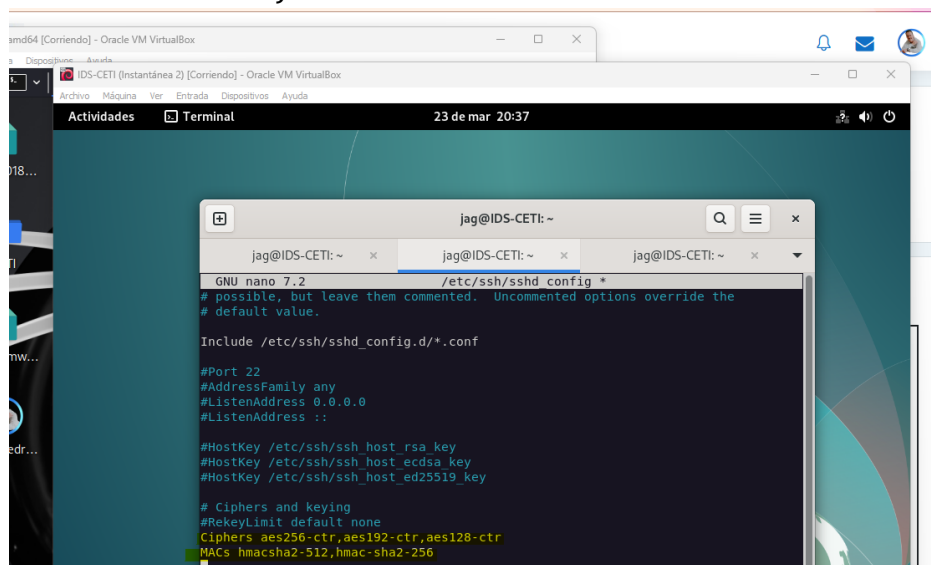


Añadimos los cifrados y algoritmos empleados en nuestro archivo de configuración.

```
sudo nano /etc/ssh/sshd_config
```

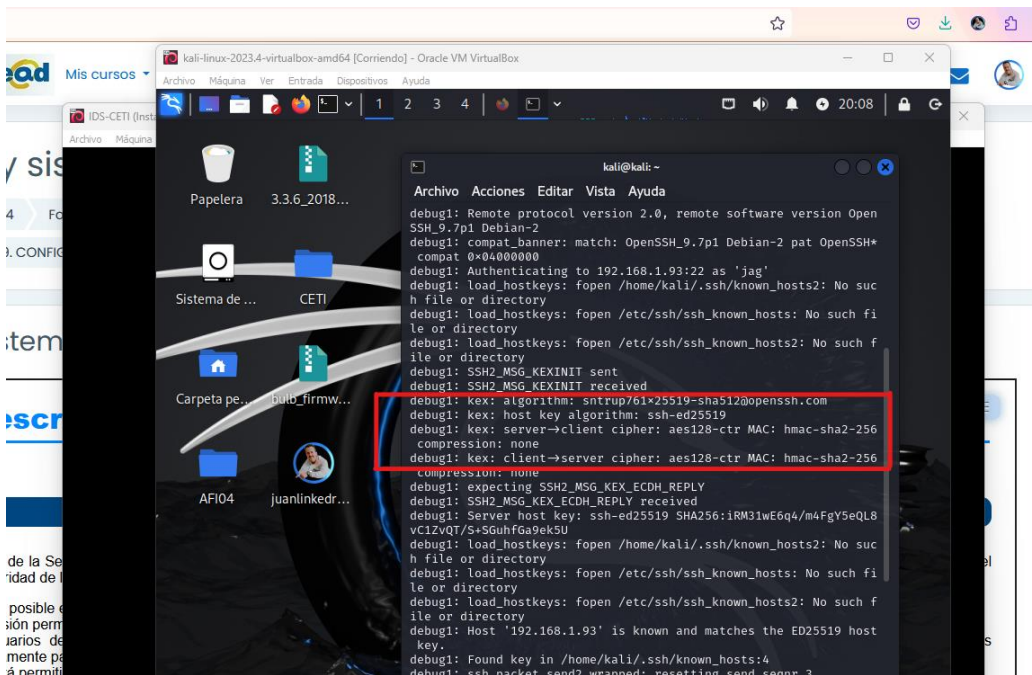
Ciphers aes256-ctr,aes192-ctr,aes128-ctr

MACs hmac-sha2-512,hmac-sha2-256



Guardamos y reiniciamos el servidor con **systemctl restart ssh**.

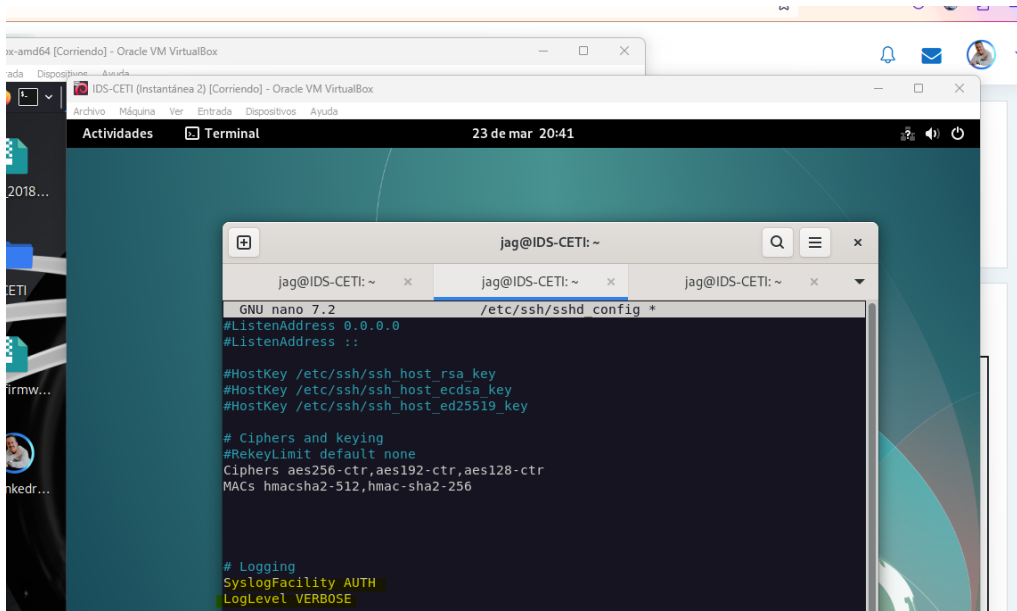
Volvemos a ejecutar la misma prueba y podemos comprobar la modificación.



10. Los logs del servicio están activados para poder enviárselos al SOC.

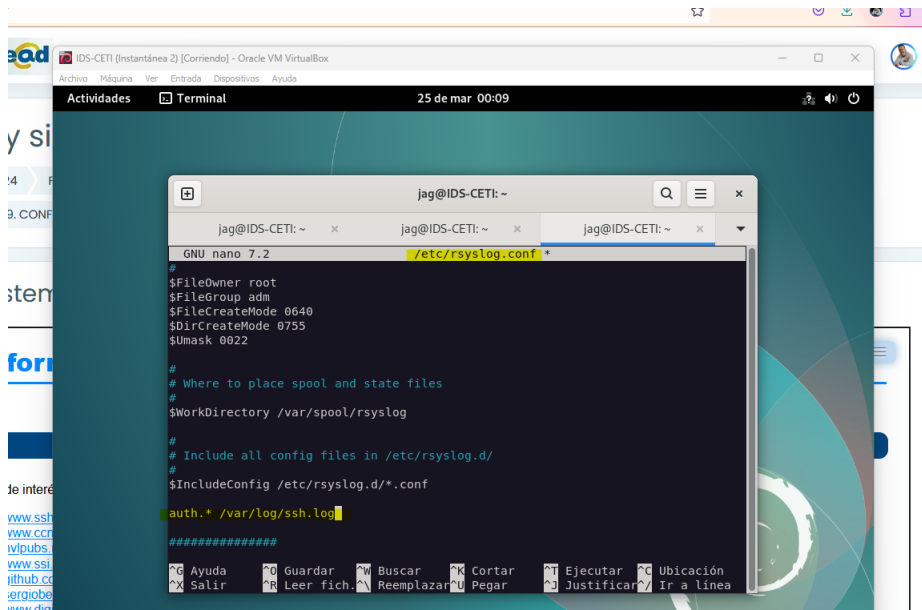
Vamos a indicar en el archivo de configuración que los registros de actividad de este servicio serán enviados mediante **AUTH** y el nivel de detalle (**VERBOSE**, es el más detallado sin violar la privacidad).

SyslogFacility AUTH
LogLevel VERBOSE



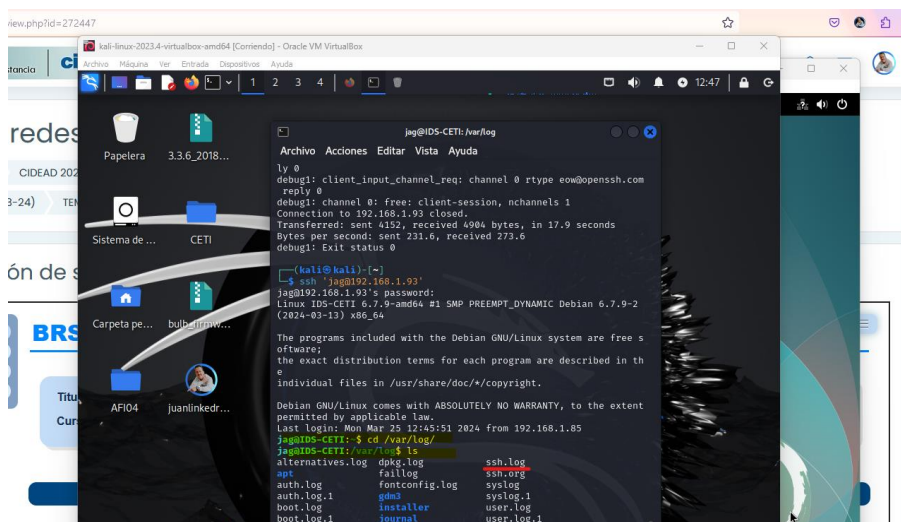
Guardamos y con esto ya podría generar los logs. Ahora vamos al fichero **/etc/rsyslog.conf** para poder enviar los logs al **SOC**:

auth.* /var/log/ssh.log

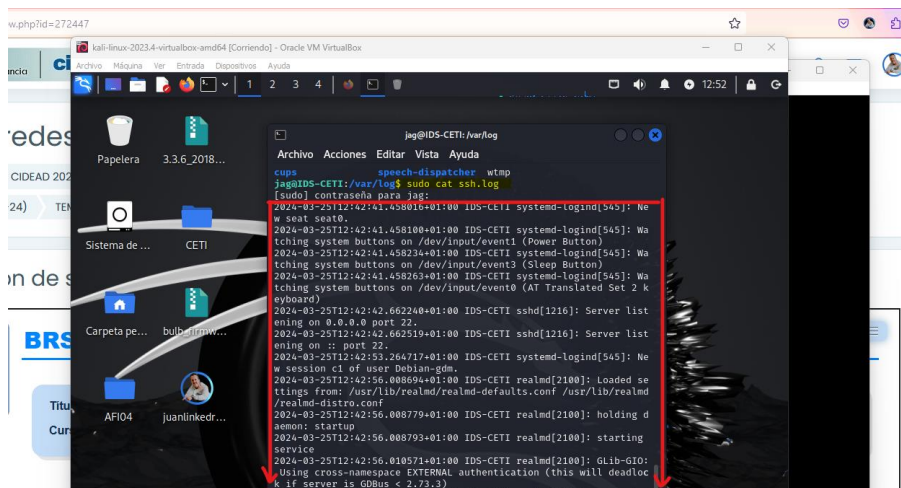


Guardamos y reiniciamos una vez más el servidor.

Podemos comprobar la generación del nuevo archivo que configuramos.



Si accedemos al mismo, accedemos a la información de los registros.



Webgrafía.

<https://www.mecd.es/cidead/aulavirtual/course/view.php?id=2368#section-9>

<https://www.digitalocean.com/community/tutorials/como-configurar-claves-de-ssh-en-ubuntu-16-04-es>

<https://www.digitalocean.com/community/tutorials/ssh-essentials-working-with-ssh-servers-clients-and-keys>

https://www.ssh.com/academy/ssh/sshd_config

https://man.openbsd.org/ssh_config.5#tun-connection

<https://www.tecmint.com/auto-disconnect-inactive-or-idle-ssh-connections-in-linux/>

<https://juncotic.com/bloques-match-configurando-ssh-server-al-detalle/>

<https://medium.com/mi-rincon/howto-configuraci%C3%B3n-sshd-con-algoritmos-de-cifrado-correctos-59bc91af4429>

<https://github.com/jtesta/ssh-audit>

https://linux.die.net/man/5/sshd_config

<https://moreillon.medium.com/ssh-reverse-shells-5094d9be2094>

<https://www.ccn-cert.cni.es/pdf/guias/series-ccn-stic/guias-de-acceso-publico-ccn-stic/3674-ccn-stic-619-implementacion-de-seguridad-sobre-centos7/file.html>

<https://nvlpubs.nist.gov/nistpubs/ir/2015/nist.ir.7966.pdf>

<https://www.ssi.gouv.fr/en/guide/openssh-secure-use-recommendations/>

<https://sergiobelkin.com/posts/como-usar-certificados-ssh-para-autenticar/>